

COMP432 – Network Security

Lab Assignment 2

Points: 100 possible (10% of final grade)

Due Date: 16th of May 2026

Loucas Mouttotou

Part 1: Report for SPF, DKIM, DMARC

Email Authentication Mechanisms: SPF, DKIM and DMARC

Introduction

Email remains one of the most common attack channels because the original SMTP protocol was designed in a trusted environment and did not include strong sender authentication. This weakness makes it easy for attackers to forge email headers and send messages that appear to come from trusted people or organizations. SMTP messages are easily spoofed, which is why organizations use SPF, DKIM and DMARC to prevent unauthorized email delivery and reduce phishing and spoofing attacks.

How SPF Works

Sender Policy Framework (SPF) is an email authentication mechanism that allows a domain owner to specify which mail servers are authorized to send email on behalf of that domain. This is done through a TXT record in DNS.

1. When a receiving mail server gets an email, it checks the sending server's IP address against the SPF record of the sender's domain.
2. If the server is listed as authorized, the email passes SPF.
3. If it is not listed, the email may fail SPF and can be marked as suspicious or rejected.

SPF helps prevent attackers from sending emails using a forged domain because unauthorized servers will not match the domain's SPF policy.

How DKIM Works

DomainKeys Identified Mail (DKIM) uses cryptographic signatures to verify that an email has not been altered during transit and that it was signed by a mail server authorized by the domain.

1. When an organization sends an email, its outgoing mail server signs parts of the message header and body using a private key.
2. The receiving mail server retrieves the sender's public key from DNS and uses it to verify the signature.
3. If the signature is valid, DKIM confirms that the signed parts of the message have not been modified and that the message was signed by a server authorized by the domain.

DMARC Policy

Domain-based Message Authentication, Reporting and Conformance (DMARC) builds on SPF and DKIM. DMARC allows domain owners to publish a policy in DNS telling receiving servers what to do when an email fails SPF or DKIM checks.

1. The policy can be set to “none,” “quarantine,” or “reject.”
2. DMARC also introduces reporting, allowing domain owners to receive reports about messages sent using their domain.
3. A key part of DMARC is alignment: the domain shown in the visible “From” header must align with the domain authenticated by SPF or DKIM.

This makes it harder for attackers to pass authentication using one domain while pretending to be another in the email shown to the user.

How They Work Together

Together, SPF, DKIM and DMARC provide layered protection.

- SPF checks whether the sending server is authorized.
- DKIM checks whether the message is signed and unchanged.
- DMARC connects these results to the visible sender domain and applies an enforcement policy.

This combination helps reduce phishing, spoofing and unauthorized email delivery. However, these mechanisms do not stop every attack. Attackers can still register lookalike domains and try to compromise legitimate organization accounts.

Challenges and Misconfigurations

There are also common implementation challenges:

- A common SPF issue is using overly strict settings such as *-all* or weak policies like *~all*, which allow suspicious mail to pass more easily.
- A common DKIM challenge is key management and rotation. Using 2048 bit keys instead of 1024 bit makes the signature stronger. Also, keys should be rotated periodically, and the private key must never be published.
- DMARC is often misconfigured by leaving the policy at *p=none* permanently, which only monitors email but does not block unauthorized emails. Attackers can exploit this because emails may still be delivered even when authentication failures are detected.

Part 2: SPF, DKIM, DMARC Configuration Guide

A. SPF Configuration:

```
securemail.com IN TXT "v=spf1 a:mail.securemail.com a:smtp.partner.com -all"
```

Figure 1: DNS TXT records for SPF

- The *a:mail.securemail.com* and *a:smtp.partner.com* mechanisms authorize the IP addresses resolved from these hostnames to send email for *securemail.com*.
- The *-all* qualifier creates a strict fail, meaning any email sent from a server not listed in the SPF record should be rejected.

B. DKIM Configuration:

Step 1: Generate DKIM Key Pair

- The administrator should generate a public-private key pair. If the domain provider supports 2048-bit key, then that is recommended because it is stronger than older 1024-bit keys. The private key must never be shared publicly.
- A DKIM selector is a unique identifier (string) used to locate a specific public key in the TXT records. Examples of a selector include provider-specific like *google*, department-specific like *marketing*, time-specific like *y2026* and generic ones like *s1*. For this lab we will use a generic one like *s1*

Step 2: Add Public Key to DNS Records

After generating the DKIM key pair, the public key should be added as a DNS TXT record. The record should look something like this:

```
s1._domainkey.securemail.com. IN TXT "v=DKIM1; k=rsa; p=INSERT_PUBLIC_KEY"
```

Figure 2: DNS TXT Record for DKIM.

Publishing the public key in DNS allows external receiving mail servers to verify that emails from *securemail.com* were signed with the matching private key.

Step 3: Signing outgoing emails using the private key

Every email sent from authorized email servers is signed using the DKIM private key.

- When an email is sent, the mail server *securemail.com* adds a DKIM-Signature header containing the signing domain **d=securemail.com** and the selector **s=s1**.
- The receiving server then retrieves the public key from DNS and verifies the digital signature.
- If the signature is valid, this confirms that the email was authorized by *securemail.com* and that the signed parts of the message were not modified during transit.

C. DMARC Configuration:

DMARC provides policies on how email servers process emails and reports actions to domain owners. A safe DMARC policy should begin in monitoring mode and gradually move to strict enforcement.

Stage 1: Monitoring Mode

```
_dmarc.securemail.com text = "v=DMARC1; p=none; pct=100; rua=mailto:dmarc-notifications@securemail.com; ruf=mailto:dmarc-notifications@securemail.com; ri=43200; fo=1; aspf=r; adkim=r;"
```

Figure 3: DMARC record in monitoring mode.

- The **p=none** policy does not block emails. It only collects reports. This allows administrators to see whether legitimate services are passing SPF and DKIM before enforcing stricter rules.
- After reviewing reports and fixing legitimate failures, the policy can be changed to quarantine suspicious emails.

Stage 2: Quarantine Mode

```
_dmarc.securemail.com text = "v=DMARC1; p=quarantine; pct=50; rua=mailto:dmarc-notifications@securemail.com; ruf=mailto:dmarc-notifications@securemail.com; ri=43200; fo=1; aspf=r; adkim=r;"
```

Figure 4: DMARC record in quarantine mode.

- The **p=quarantine** policy tells receiving servers to place failing emails into spam or quarantine.
- The **pct=50** tag applies the policy to 50% of failing emails at first, reducing the risk of accidentally blocking legitimate emails.
- Once the domain owner confirms that all legitimate mail sources pass authentication, DMARC can move to full rejection.

Stage 3: Strict Enforcement

`_dmarc.securemail.com text = "v=DMARC1; p=reject; pct=100; rua=mailto:dmarc-notifications@securemail.com; ruf=mailto:dmarc-notifications@securemail.com; ri=43200; fo=1; aspf=r; adkim=r;"`

Figure 5: DMARC record in strict enforcement.

- The **p=reject** policy and **pct=100** instructs receiving mail servers to reject emails that fail DMARC.
- This provides the strongest protection against spoofing and phishing using *securemail.com*.

Part 3: Domain list Analysis

Introduction

This section analyses the SPF, DKIM and DMARC configuration of 5 domains: **google.com**, **bbc.co.uk**, **apple.com**, **microsoft.com** and **paypal.com**. The analysis of the SPF record was performed using the command-line tool *dig*. To check DKIM, I used a received email header to identify the DKIM selector *s=* and signing domain *d=*. I then queried the DNS TXT record at *selector._domainkey.domain.com* using MXToolbox - DKIM Lookup. Lastly the analysis of the DMARC policy was done with the command-line tool *nslookup*. At the end, a comparison table is included to summarize the differences between the domains in terms of SPF, DKIM, DMARC.

Google.com

i. SPF Record

A terminal window with a dark purple background. The prompt is 'loucas@Network-Security:~\$'. The first command is 'dig google.com txt | grep spf'. The output shows 'google.com. 300 IN TXT "v=spf1 include:_spf.google.com ~all"'. The second command is 'dig _spfgoogle.com txt | grep spf'. The output shows a multi-line response starting with '; <<>> DiG 9.18.39-0ubuntu0.24.04.2-Ubuntu <<>> _spfgoogle.com txt' and ending with '; _spfgoogle.com. IN TXT'. The prompt is now 'loucas@Network-Security:~\$' with a cursor.

```
loucas@Network-Security:~$ dig google.com txt | grep spf
google.com.          300    IN      TXT     "v=spf1 include:_spf.google.com ~all"
loucas@Network-Security:~$ dig _spfgoogle.com txt | grep spf
; <<>> DiG 9.18.39-0ubuntu0.24.04.2-Ubuntu <<>> _spfgoogle.com txt
; _spfgoogle.com.      IN      TXT
loucas@Network-Security:~$
```

Figure 6: SPF record for google.com.

- The ~all qualifier means soft fail.
- This indicates that unauthorized senders should be treated as suspicious but not necessarily rejected only because of SPF.

ii. DKIM Record

[illegible]

Figure 7: DKIM record for google.com.

- The DKIM lookup for google.com was performed using the selector 20251104 (*probably referring to a y/d/m*), giving the DNS query 20251104._domainkey.google.com.
- Google uses RSA 2048-bit for encryption.
- This means that when Google sends an email signed with the selector 20251104, the receiving mail server can retrieve the public key from 20251104._domainkey.google.com and verify that the message was signed by Google's private key and was not modified during transmission.

iii. DMARC Record

```
lucas@Network-Security: ~$ nslookup -type=txt _dmarc.google.com
Server:      127.0.0.53
Address:     127.0.0.53#53

Non-authoritative answer:
_dmarc.google.com      text = "v=DMARC1; p=reject; rua=mailto:mailauth-reports@google.com"

Authoritative answers can be found from:

lucas@Network-Security: ~$
```

Figure 8: DMARC record for google.com.

- This means emails that fail DMARC should be rejected p=reject;
- Google's DMARC policy uses p=reject, meaning emails that fail DMARC should be rejected. This is a strict policy and provides strong protection against direct spoofing of the google.com domain.

Vulnerabilities or Gaps

The SPF record uses ~all instead of -all, which is less strict. However, this is partly compensated by the strong DMARC p=reject policy.

Recommendation

- Google could use -all for stricter SPF enforcement, but changing SPF on such a large worldwide domain may affect forwarding and third-party sending systems.
- DKIM keys should not be used forever. A good practice is to rotate DKIM keys periodically, for example every 6–12 months. Key rotation reduces the risk of long-term compromise.

1. Apple.com

I. SPF Record

```

lucas@Network-Security:~$ dig apple.com txt | grep spf
apple.com.      3599      IN      TXT      "v=spf1 include:_spf.apple.com include:_spf-txn.apple.com ~all"
lucas@Network-Security:~$ dig _spfapple.com txt | grep spf
; <<>> DiG 9.18.39-0ubuntu0.24.04.2-Ubuntu <<>> _spfapple.com txt
; _spfapple.com.      IN      TXT

```

Figure 9: SPF record for apple.com.

- The record, similar to google.com example ends with ~all, meaning soft fail.

II. DKIM Record

[illegible]

Figure 10: DKIM record for apple.com.

- Apple uses RSA 2048-bit and sha256 for hash algorithms.

III. DMARC Record

```
loucas@Network-Security:~$ nslookup -type=txt _dmarc.apple.com
Server:      127.0.0.53
Address:     127.0.0.53#53

Non-authoritative answer:
_dmarc.apple.com      text = "v=DMARC1; p=quarantine; sp=reject; rua=mailto:d@rua.agari.com; ruf=mailto:d@ruf.agari.com;"
Authoritative answers can be found from:
```

Figure 11: DMARC record for apple.com.

- The main domain uses p=quarantine, while subdomains use the stricter **sp=reject** policy.
- Apple uses two different emails for rua and ruf action reporting.

Vulnerabilities or Gaps

- The main domain policy is p=quarantine, not p=reject.
- SPF uses ~all, which is less strict than -all.

Recommendation

Apple could consider moving the main domain from p=quarantine to p=reject. Its sp=reject setting for subdomains is strong and should be kept.

2. Microsoft.com

I. SPF Record

```
loucas@Network-Security:~$ dig microsoft.com txt | grep spf
microsoft.com.      3599    IN      TXT     "v=spf1 include:_spf-a.microsoft.com include:_spf-b.microsoft.com includ
e:_spf-c.microsoft.com include:_spf-ssg-a.msft.net include:_spf1-neo.microsoft.com -all"
```

Figure 12: SPF record for microsoft.com.

- Microsoft's SPF record uses stricter enforcement with -all instead of ~all.
- This means all mail coming from servers not listed in the SPF record should be rejected.

II. DKIM Record

[illegible]

Figure 13: DKIM record for microsoft.com.

- Microsoft uses rsa with 2048 bits.

III. DMARC Record

```
lucas@Network-Security:~$ nslookup -type=txt _dmarc.microsoft.com
Server:      127.0.0.53
Address:     127.0.0.53#53

Non-authoritative answer:
_dmarc.microsoft.com text = "v=DMARC1; p=reject; pct=100; rua=mailto:itex-rua@microsoft.com; ruf=mailto:itex-ruf@microsoft.com; fo=1"

Authoritative answers can be found from:
```

Figure 14: DMARC record for microsoft.com

- Microsoft has one of the strongest configurations in this analysis so far because its SPF record uses -all and its DMARC policy uses p=reject with pct=100.
- The pct=100 tag confirms full enforcement, and fo=1 requests failure reports when authentication fails.
- Action reports for rua and ruf are sent to two different emails.

Vulnerabilities or Gaps

Microsoft has a strong DMARC policy, maybe the best example so far. The main practical risk is not the DMARC policy itself, but the complexity of managing many Microsoft services, subdomains and third-party mail flows.

Recommendation

Microsoft should continue monitoring DMARC reports and maintain strong DKIM key rotation.

Not much else to say.

3. Paypal.com

i. SPF Record

```

Lucas@Network-Security:~$ dig paypal.com txt | grep spf
paypal.com.      300      IN       TXT      "v=spf1 include:pp._spf.paypal.com include:3ph1._spf.paypal.com include:
3ph2._spf.paypal.com include:3ph3._spf.paypal.com include:3ph4._spf.paypal.com include:sendgrid.net include:aspmx.pardot
.com ~all"

```

Figure 15: SPF Record for paypal.com.

- The SPF record indicates that PayPal uses multiple internal and external mail platforms to send email.
- The SPF record ends with *~all*, which means soft fail. This means that mail from unauthorized servers should be treated as suspicious, but not automatically rejected based only on SPF.

[illegible]

Figure 16: DKIM record of paypal.com.

- PayPal uses RSA with 2048-bit keys.

```
lucas@Network-Security: ~$ nslookup -type=txt _dmarc.paypal.com
Server:      127.0.0.53
Address:     127.0.0.53#53

Non-authoritative answer:
_dmarc.paypal.com      text = "v=DMARC1; p=reject; rua=mailto:d@rua.agari.com; ruf=mailto:d@ruf.agari.com"

Authoritative answers can be found from:
```

Figure 17: DMARC record for paypal.com.

- PayPal's DMARC policy is strict because it uses $p=reject$.
- PayPal uses two different emails for rua and ruf action reporting.
- This strict DMARC policy from PayPal is very good because it is a high-value phishing and spoofing target.

Vulnerabilities or Gaps

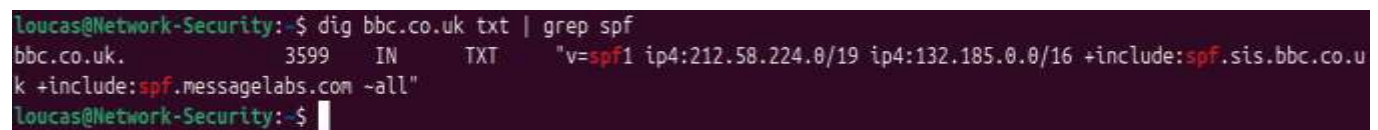
A possible weakness is that PayPal uses *~all* instead of *-all*. A soft fail policy may allow some unauthorized emails to be accepted or placed into spam rather than rejected. However, this may be intentional because PayPal uses several third-party mail services, and a hard fail could accidentally block legitimate mail if all sending sources are not perfectly configured.

Recommendation

PayPal should continue using strong DKIM keys and rotate selectors periodically. Since PayPal uses several sending platforms, each third-party sender should have DKIM configured correctly and aligned with the PayPal domain where possible.

4. Bbc.co.uk

i. SPF Record



```
loucas@Network-Security:~$ dig bbc.co.uk txt | grep spf
bbc.co.uk. 3599 IN TXT "v=spf1 ip4:212.58.224.0/19 ip4:132.185.0.0/16 +include:spf.sis.bbc.co.uk +include:spf.messagelabs.com ~all"
loucas@Network-Security:~$
```

Figure 18: SPF record for *bbc.co.uk*.

- This record authorizes two IPv4 ranges, 212.58.224.0/19 and 132.185.0.0/16, meaning mail from these BBC-controlled IP ranges is allowed to send email for *bbc.co.uk*.
- It also includes two external SPF records: *spf.sis.bbc.co.uk* and *spf.messagelabs.com*.
- This suggests that BBC uses both internal and a third-party email/security service for email delivery.
- The record ends with *~all*, which means SPF soft fail. This means mail from unauthorized servers should be treated as suspicious but not automatically rejected based only on SPF.

ii. DKIM Record

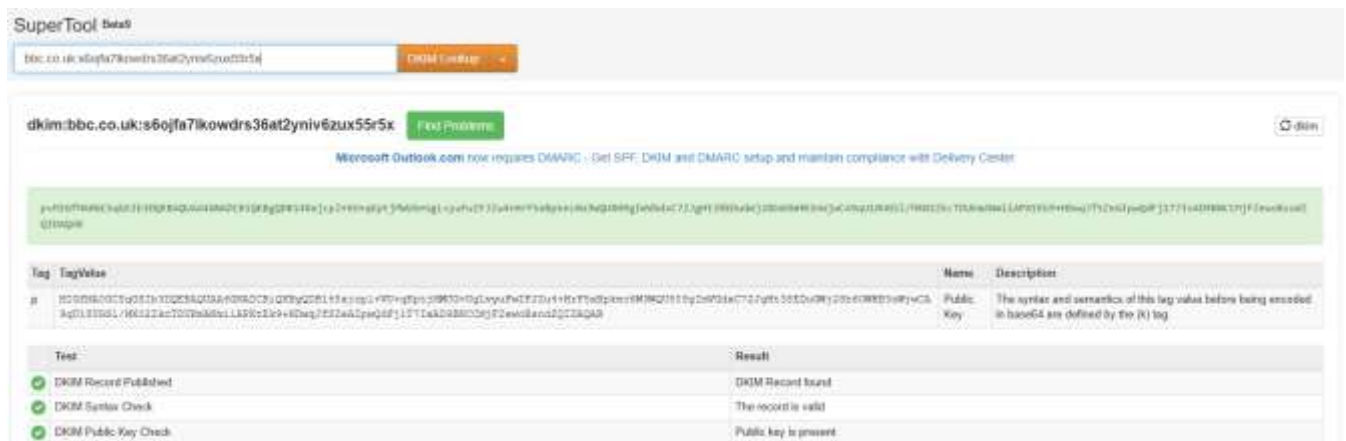


Figure 19: DKIM record for bbc.co.uk.

- BBC uses a big string as a selector: s6ojfa7lkowdrs36at2yniv6zux55r5x
- Unlike previous DKIM examples, BBC's record does not clearly show extra tags such as v=DKIM1 or k=rsa.
- However, this is not necessarily a problem because MXToolbox confirms that the DKIM record is valid and that the public key is present.

iii. DMARC Record



Figure 20: DMARC record for bbc.co.uk.

- The policy p=reject means that emails failing DMARC should be rejected by receiving mail servers.
- The pct=100 tag means this policy applies to 100% of failing messages.
- BBC also uses strict alignment for both SPF and DKIM because the record includes aspf=s and adkim=s. This means the authenticated SPF or DKIM domain must strictly match the visible sender domain.
- The rua=mailto:dmarc_agg@vali.email tag means aggregate DMARC reports are sent to that address. The ri=86400 tag means reports are requested every 86,400 seconds, or

once per day. The fo=0 tag means failure reports are only requested when both SPF and DKIM fail to produce a DMARC pass.

Vulnerabilities or Gaps

- The main weakness is that the SPF record ends with *~all*, meaning soft fail, instead of *-all*, which would be stricter. However, this weakness is partly reduced by BBC's strong DMARC policy.
- Another possible issue is that the SPF record includes external services, such as MessageLabs, so BBC must ensure these third-party services remain secure and correctly configured.

Recommendation

- BBC could consider changing from *~all* to *-all*, but only after confirming that all legitimate internal and third-party sending sources are correctly included.
- BBC should also consider reports on real-time failed emails through ruf. Reports should be sent to a trusted address but different from dmarc_agg@vali.email that is used for rua reports.
- BBC should also rotate DKIM keys periodically to reduce the risk of long-term key compromise.

Comparison Table

Domain	SPF	DKIM	DMARC	Conclusion
Google.com	~all	RSA 2048-bit	p=reject	Strong DMARC, SPF could be stricter.
Apple.com	~all	RSA 2048-bit / SHA-256	p=quarantine, sp=reject	Good, but main policy could move to reject.
Microsoft.com	-all	RSA 2048-bit	p=reject; pct=100	Strong overall configuration.
Paypal.com	~all	RSA 2048-bit	p=reject	Strong DMARC, SPF could be stricter.
Bbc.co.uk	~all	Not shown	p=reject; pct100; aspf=s; adkim=s	Strong DMARC, SPF could be stricter.